

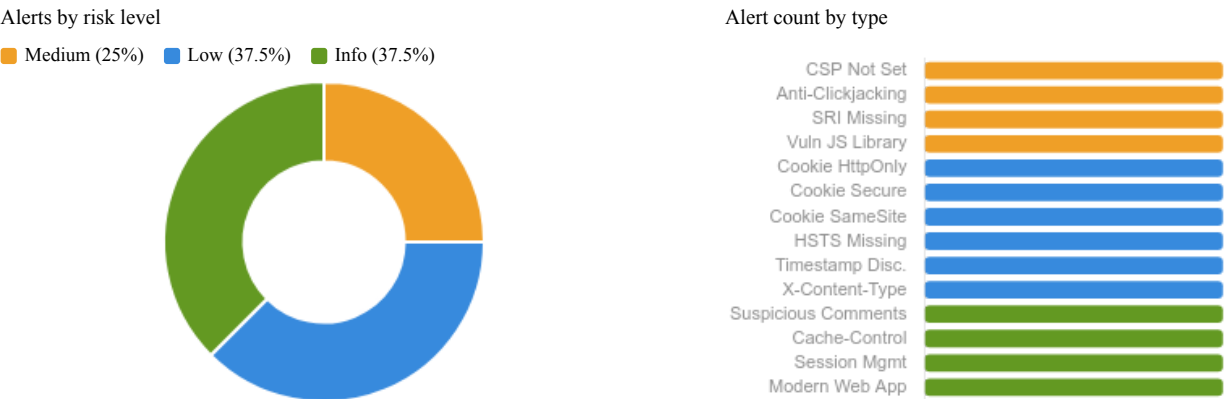
16
Total alerts

4
Medium risk

6
Low risk

6
Informational

Risk & confidence distribution



Finding inventory

FINDING	RISK	SOURCE	DESCRIPTION
CSP Header Not Set	Medium	ZAP	No Content-Security-Policy prevents XSS and injection
Missing Anti-Clickjacking	Medium	ZAP	No X-Frame-Options / frame-ancestors directive
Sub-Resource Integrity Missing	Medium	ZAP	External scripts loaded without integrity hash
Vulnerable JS Library	Medium	ZAP	Outdated JS library with known CVEs detected
Cookie No HttpOnly Flag	Low	Nikto/ZAP	connect.sid accessible via JavaScript
Cookie Without Secure Flag	Low	Nikto/ZAP	Session cookie may transmit over plain HTTP
Cookie No SameSite Attribute	Low	ZAP	CSRF risk — no SameSite=Strict/Lax set
HSTS Header Not Set (HTTP)	Low	ZAP	HTTP endpoint lacks Strict-Transport-Security
Timestamp Disclosure	Low	ZAP	Unix timestamps in responses aid fingerprinting
X-Content-Type-Options Missing	Low	Nikto/ZAP	MIME-sniffing not disabled (nosniff absent)
BREACH Attack Vector	Low	Nikto	Content-Encoding: deflate + HTTPS may allow BREACH
Referrer-Policy Missing	Info	Nikto	Referrer data may leak to third-party requests
Permissions-Policy Missing	Info	Nikto	Browser features unrestricted (camera, geo, etc.)
Info Disclosure – Comments	Info	ZAP	Source comments may reveal internal paths/logic
Cache-Control Directives	Info	ZAP	Sensitive pages may be cached by intermediaries
Session Mgmt Response ID	Info	ZAP	Session token present in observable responses

Tooling used

Nmap 7.99 (port scan) WhatWeb (tech fingerprint) Nikto v2.6.0 (web scan) OWASP ZAP 2.17.0 (passive scan) Chromium DevTools (manual)

Infrastructure summary

Network	Application stack
IP: 129.80.84.189	Framework: Bootstrap + jQuery
Open ports: 80/tcp, 443/tcp	Script type: application/json, module
Server: nginx (reverse proxy)	Cookie: connect.sid (Node.js session)
TLS cipher: ECDHE-RSA-AES256-GCM-SHA384	HTTP→HTTPS: 308 permanent redirect
CA: Let's Encrypt (R13)	HSTS: max-age=31536000; includeSubDomains

Priority remediation recommendations

- 1 Implement Content-Security-Policy — define strict source allowlists. Current response uses `unsafe-inline` and `unsafe-eval`, negating XSS protection entirely.
- 2 Harden session cookie attributes — add `HttpOnly`, `Secure`, and `SameSite=Strict` to `connect.sid` to prevent XSS theft and CSRF.
- 3 Add X-Frame-Options or CSP frame-ancestors — prevents clickjacking attacks on unauthenticated and authenticated pages.
- 4 Add Sub-Resource Integrity (SRI) hashes — all externally hosted scripts and stylesheets should include `integrity` and `crossorigin` attributes.
- 5 Update vulnerable JS library — identified library has known CVEs; patch to latest stable version immediately.
- 6 Set missing response headers — add `X-Content-Type-Options: nosniff`, `Referrer-Policy`, and `Permissions-Policy` globally via nginx config.